

Intégration AD du Bastion Linux (SSSD & Tiering)

Objectifs :

- Comprendre l'intérêt de la centralisation des identités pour les systèmes Linux.
- Maîtriser l'architecture de SSSD (Kerberos + LDAP).
- Éviter le piège de la rupture de Tiering lors de la jonction d'un Linux au Domaine.
- Restreindre les accès SSH via les groupes Active Directory.

1. Pourquoi joindre un Linux à l'Active Directory ?

Dans une infrastructure moderne, la gestion des comptes locaux sur les serveurs Linux (/etc/shadow) est un cauchemar d'audit et de sécurité.

- **La désynchronisation** : Lorsqu'un administrateur quitte l'entreprise, son compte AD est désactivé, mais son compte local sur le serveur Linux reste souvent actif. C'est un compte orphelin (vecteur d'attaque majeur).
- **La traçabilité (SOC)** : Si tout le monde se connecte avec le compte générique root ou admin_linux, il est impossible de savoir *qui* a réellement tapé une commande.
- **La solution** : Connecter le Linux à l'Active Directory. L'utilisateur utilise son compte Windows (jdupont) pour se connecter en SSH au serveur Linux. S'il quitte l'entreprise, la désactivation de son compte AD lui coupe instantanément l'accès aux serveurs Linux.

2. Comment un Linux "parle" à un Windows

Le standard de l'industrie (poussé par RedHat, Ubuntu et l'ANSSI) est **SSSD** (System Security Services Daemon).

2.1 Les deux piliers de l'authentification

Contrairement à Windows qui gère tout de manière opaque, Linux sépare strictement l'identité de l'authentification :

1. **L'Identité (Qui êtes-vous ?) - Protocole LDAP** :
SSSD va interroger le Contrôleur de Domaine (DC) en LDAP pour récupérer le profil de l'utilisateur (Son nom, son UID, les groupes AD auxquels il appartient).
2. **L'Authentification (Prouvez-le) - Protocole Kerberos** :
Linux ne va *jamais* envoyer votre mot de passe en clair. SSSD contacte le KDC (Key Distribution Center) de l'Active Directory. Si le mot de passe est bon, le DC renvoie un **Ticket Kerberos (TGT)** au Linux.

2.2 L'avantage de SSSD (Le Cache hors ligne)

SSSD possède une base de données de cache locale. Si le Contrôleur de Domaine tombe en

panne ou que le lien réseau est coupé, l'administrateur peut toujours se connecter au serveur Linux avec son compte AD : SSSD validera l'accès grâce au cache (empreintes) conservé localement, garantissant la résilience du Bastion.

3. La Rupture du Modèle en Tiers

Le postulat : Vous intégrez un serveur Linux hautement sécurisé (un Bastion, Tier 0) dans votre Active Directory.

Le problème par défaut : Dès que le Linux est joint au domaine, **tous les utilisateurs de l'AD** (ou a minima tous les Admins du Domaine) ont techniquement la possibilité d'essayer de s'y connecter en SSH.

3.1 La violation des chemins de contrôle

Si le groupe "Admins du Domaine" (Tier 0) utilise le Bastion Linux, mais que le support Helpdesk (Tier 2) a également le droit d'ouvrir une session SSH sur ce Linux (même sans droits sudo), le modèle en Tiers est rompu.

Un attaquant ayant compromis le Tier 2 pourrait rebondir sur le Linux, scanner la mémoire et y trouver les tickets Kerberos (ou frapper la socket SSH) des administrateurs Tier 0.

3.2 L'Exigence : Le filtrage des ouvertures de session (Logon Rights)

La sécurité exige que le moteur SSSD du serveur Linux soit bridé :

Il ne doit interroger l'AD **QUE** pour valider un groupe de sécurité extrêmement précis.

Exemple de restriction stricte dans sshd_config ou SSSD :

Autoriser uniquement le groupe Admins_LAPS_Tier0. Toute autre tentative (même par l'Administrateur du Domaine natif) sera rejetée au niveau du module PAM (Pluggable Authentication Modules), avant même la vérification du mot de passe.

4. Délégation des privilèges (Sudoers via AD)

Une fois l'utilisateur AD autorisé à se connecter, quels sont ses droits sur le Linux ?

Par défaut : aucun. C'est un utilisateur standard.

Pour lui donner les droits d'administration, on ne modifie pas son compte local. On crée une liaison (Mapping) entre un groupe de sécurité Active Directory et le fichier /etc/sudoers de Linux.

Exemple de configuration dans le sudoers :

```
%Admins_LAPS_Tier0@formation.local ALL=(ALL:ALL) ALL
```

Conclusion de la séquence :

Grâce à SSSD, PAM et SSH, le serveur Linux devient une extension naturelle de l'Active Directory, tout en respectant un cloisonnement beaucoup plus strict et granulaire qu'un serveur Windows standard. L'hygiène des comptes est parfaite, et le SOC dispose d'une traçabilité centralisée (Syslog) associant les actions Linux aux identités AD.